

***Today's biggest cyberattacks
don't start from your code..
They start from the packages
you trusted blindly***

What is SBOM?

(Software Bill of Materials)

- A complete inventory of all software components used in an application
 - Includes:
 - Libraries
 - Dependencies
 - Packages
 - Versions
- Similar to an “ingredients label” for software

Why SBOM is Important in Industry?

- Helps organizations understand:
- What software components they are using
- Which dependencies are vulnerable
- Critical for:
- Supply chain security
- Compliance
- Incident response
- Became highly important after attacks like:
- Log4Shell
- SolarWinds

Real Industry Problem

- Many companies use open-source dependencies
blindly
- Vulnerability in one dependency can affect:
 - Thousands of applications
 - Entire organizations
- Without SBOM:
- Teams don't know what exists inside their software

SBOM in DevSecOps

- Enables:
- Transparency
- Traceability
- Continuous vulnerability management
- Helps security teams quickly identify:
- Affected systems
- Risk exposure

Syft

(SBOM Generation Tool)

Grype

(Vulnerability Scanning Tool)

Syft + Grype Workflow

Why This is a 2026 Must-Have Skill?